

LEARNATHON 5.0 CYBER SECURITY HACKATHON

HOSTELGRIEVANCE

Zero-Trust University Grievance Platform

Made by Manan Patel 24CSE015, Team Apex

Live Website fully working with Cloud Sqlite.

<https://giet-learnathon-5-0.onrender.com>

github name : manan933

github repo :

<https://github.com/manan933/GIET-Learnathon-5.0>

List of All Solutions & Fixes I have added.

1. **Salted Script Authentication** - Hashes password with unique 128 bits random values.
2. **AES-256-GCM Encryption** - Advanced encryption standard counter mode, Encrypts everything so database store no plain text.
3. **Strict IDOR/BOLA protection** - Blocks student from viewing and other thing on other student's data.
4. **Account Lockout** - Locks account for a specific time period after 3 attempts and 5 attempts with increasing time. For displaying this 3 attempt failure lock is 10 seconds only and 5 attempt is of 15 seconds lock only. Note: this will be reported in security logs of Warden & Student.
5. **3 Factor Multi password for Recovery** - lets student and warden reset password. 3 different passwords required for unlocking reset - 1st will be Numerical pin, 2nd will be a word, 3rd will be symbols.
6. **HavelBeenPwned checker** - A OpenSource tool, which rejects compromised passwords by checking 800M+ Compromized passwords collected by Hackers in last decade.
7. **Automated EXIF image stripper** - Strip image metadata (location,number,other details) before uploading to database ,so Hacker can't get location details from Images.
8. **Binary Magic byte verification** - process of inspecting few bytes of file to confirm it's true format , In this way it blocks malicious hidden files.
9. **XSS sanitization** - eliminates HTML & Script characters when inputted anywhere . For Example <script> will be converted to <script&lb ,this prevents hackers inputting injections in forms fields.

10. **Protected Downloads** - Only warden can access images.
11. **Realtime Security threats** - Provides Security logs page to inspect unauthorized login, alerts & other risky security details.
12. **Unregistered Account** - logs attempted for non verified email, It's email & IP address will be sent to Warden in Security Logs.
13. **GeoIP Travel alert** - Flags suspicious login occurring from distant geolocation in impossible timing. For example - BBSR location in 1st login after logout then 2nd login after 5 minutes location Vizag will be flagged suspicious.
14. **Turso Cloud database** - Cloud Sqlite Server , with Parameterized SQL queries which will prevent SQL injection with Everything encrypted in it , Data stays forever.
15. **Rate limiting** - 10 Request/minutes per IP address preventing DDOS attacks
16. **Activity Logs** - Different from Security Logs so it doesn't get messed up , Contains all detailed actions of a user.
17. **Login Location** - Login location through IP will be always recorded in LOGS.
18. **Web Crawlers** - Blocks some known Crawlers & AI bots (NOT ALL) , can be done by manually adding crawler name in code.
19. **Right Click & Inspect tools** - Disabled Right Click and Inspect tools & other key Combinations.
20. **Anti ClickJacking** - Prevents Application from being framed in malicious frame tags.
21. **Attachment CSP sandbox** - See images where code cannot be execute.
22. **Information disclosure** - Shows normal error screens on any type of failures, So hackers can never get a clue what exactly Failed or is vulnerable.

- 23. **Session Destruction** - Deletes sessions after sometime after signing out So hacker cannot replay old tokens.
- 24. **HTTPOnly Cookies** - Secures JS Session theft or XSS.
- 25. **Session Expiration lifecycle** - When inactivity of 5 mins, it will automatically logout. (Note: Right now this features won't work cause I have used CronJob - A tool which sends request to server every minute to prevent the server from sleeping.
- 26. **K-Anonymity Password Privacy** - Sends first few characters of Passwords with salted hashing to HavelbeenPwned API , ensuring full password never goes there.

Observed Vulnerabilities

The Baseline Dilemma: Data Exposure & Broken Authorization

Data & Reporting Gaps

- IDOR allowed viewing and editing tickets of other
- students.
- unauthorized photo downloads via direct link guessing

Resource Utilization

- SQLite dumped plain-text grievances & student room info.
- EXIS GPS metadata leaked student locations.

Patient Management

- Unlimited password guesses without logout.
- Unsalted password hashes vulnerable to rainbow tables.

Malicious File & Script Injection

- The Risk: Without server-side binary magic byte inspection, attackers could upload executable scripts or webshells disguised as PNG/JPEG files to compromise the host server.

Stored XSS & Session Hijacking

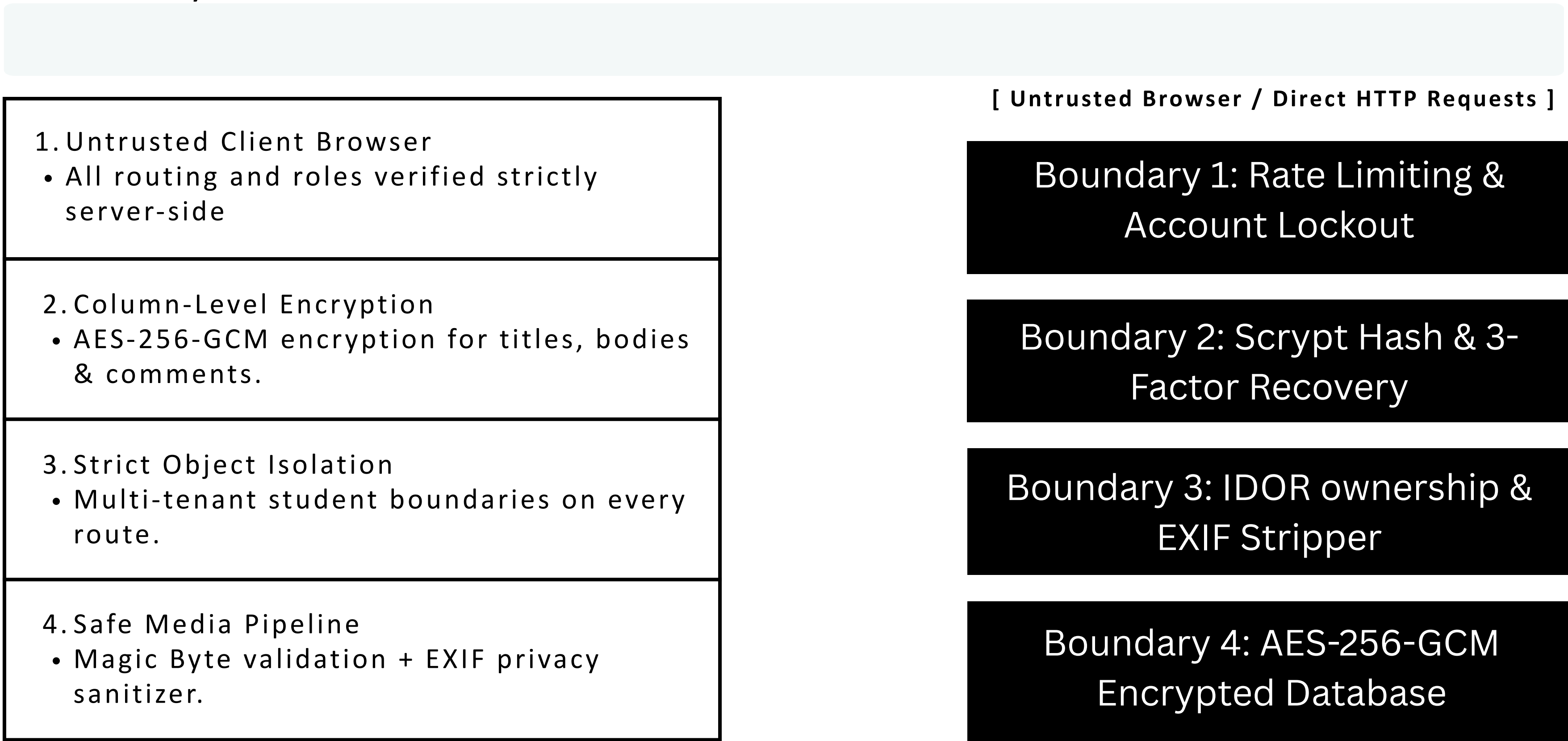
- The Risk: Unsanitized complaint titles, descriptions, and comments allowed malicious <script> tags to execute in victims' browsers, enabling silent session theft.

Information disclosure & Zero Security visibility

- The Risk: Unhandled errors leaked database schema names and stack traces to clients, while the absence of audit logs left administrators completely blind to active credential stuffing and impossible travel attacks.

ARCHITECTURE & DEFENSE-IN-DEPTH

Zero-Trust Security Model



Key Innovations & Security Hardening

Column-Level AES-256-GCM

- Titles, descriptions, and comments stored as `enc:v1:<iv>:<tag>:<cipher>`
- Each factor independently salted |
- Decrypted strictly in server memory.

3-Factor Multi-Secret Recovery

- Numeric PIN + Word + Symbol Key.
- Each factor independently salted with Scrypt & constant-time compare.

Progressive Account Lockout

- 3 fails = 10s lock; 5 fails = 15s lock
- time can be changed 15s-15m-15hours or even years.
- Active sessions revoked on lock.
- Reactive UI backward countdown timer.

Privacy-First Image Pipeline

- Automatic EXIF metadata stripper.
- Magic byte binary validation.
- Randomized storage names on disk.

Implementation Details

Hasing & Auth	Scrypt (N=16384, r=8, p=1) + 128-bit Salt + timingSafe
Data Encryption	AES-256-GCM with unique 12-byte IV + 16-byte Auth Tag
Breach Detection	HavelBeenPwned API integration via k-Anonymity SHA-1
Threat Monitoring	Real-time Geo-IP, Impossible Travel & Auth Audit Logs
Storage & Sync	Turso Cloud SQLite with Safe Local Replication

VALUE & IMPACT

Student Confidence

- Private issues remain strictly confidential.
- no fear of leaks.

Compliance & Privacy

- FERPA/GDPR-aligned data minimization.
- No plain-text GPS or identity leakage.

Warden Visibility

- Real time threat center for failed logins & anomalies.
- Full audit logging.

Zero Administrative Overhead & Rapid Turnaround

- The Impact: Eliminates chaotic manual paperwork and insecure WhatsApp complaint threads with a centralized, tamper-proof resolution pipeline—cutting maintenance response times from days to hours while ensuring complete institutional accountability.

Future Scope

WebAuthn / FIDO2 Hardware Security Keys (YubiKey support for Wardens)

Edge WAF & Cloudflare Turnstile automated bot protection

Hardware Security Module (HSM) key rotation for AES-256 master keys

Security is not a feature — it is the foundation

Thank you for your quality time.

*Team Apex,
Manan Patel*